



03 — Non-Functional Requirements (NFR)

TASCO Insurance × VETC Growth Platform — Business & Product

iorta TechNXT

Version 1.0 · 07 October 2026

Contents

0. Conventions
1. Performance
2. Scalability
3. Availability and resilience
4. Security (OWASP ASVS 4.0 Level 2)
5. Privacy and data protection
6. Accessibility and usability
7. Localisation
8. Maintainability and quality
9. Observability
10. Disaster recovery and backup
11. Portability and deployment
12. Auditability
13. Configurability
14. Data retention
15. Compliance-by-design (cross-cutting)

0. Conventions

- IDs are `NFR-nnn`. Each NFR has a **measurable target**, a **verification method** and its **current support in the codebase** (*Built*, *Partial* or *Planned*).
- Targets are **proposed**. They must be agreed with TASCO and VETC IT in Phase 0 and baselined in the performance test (`test/perf/load.js` , *planned*).
- Sizing reference: **6,000,000 vehicles** (VETC car base, from the brief). Workload assumptions are labelled `[W-n]` .

Workload model (assumptions)

ID	Assumption	Value
W-1	Golden profiles	6 M (12 M source records at about 2 per vehicle)
W-2	Leads re-scored nightly (full) / on events (partial)	6 M per night / ≤ 50k per hour
W-3	Touchpoints due per day at peak (month-end and Tết)	300k
W-4	Concurrent staff users	300 (telesales 200, other 100)
W-5	Customer app sessions at peak (push campaign)	2,000 requests/s for 15 minutes
W-6	Concurrent bot calls (vendor side)	200
W-7	Partner API peak	50 requests/s

1. Performance

ID	Requirement	Target	Verification	Support
NF R-001	API latency, read endpoints (leads list, customer 360, home, certificate verify)	p95 ≤ 300 ms, p99 ≤ 800 ms at W-4 / W-5 load	<code>test/perf/load.js</code> ; histogram <code>http_request_duration_seconds</code>	Partial (metrics built; load test planned)
NF R-002	API latency, quote	p95 ≤ 500 ms	Load test	Planned
NF R-003	Purchase (pay + issue) end-to-end excluding upstream latency	p95 ≤ 1.5 s; upstream timeouts 5 s with 2 retries	Load test; circuit-breaker config	Built (<code>src/shared/resilience.js</code> defaults: timeout 5,000 ms, retries 2)
NF R-004	Bot dialogue turn processing (excluding ASR and TTS)	p95 ≤ 150 ms per turn	Unit benchmark on <code>voicebot.js</code>	Planned
NF R-005	Ingestion throughput	≥ 2,000 records/s per worker; 12 M records rebuilt in ≤ 4 h with 4 workers	Batch benchmark	Partial (incremental, chunked rebuild of 500 plates)

ID	Requirement	Target	Verification	Support
NF R-006	Lead recompute	Full 6 M recompute in ≤ 3 h nightly; event-driven partial recompute visible within ≤ 60 s	Job timings in <code>job_runs</code>	Partial (paged by 1,000; parallel workers planned)
NF R-007	Journey run	300k due touchpoints executed within the 08:00–20:00 contact window in ≤ 2 h	<code>journeys.run</code> audit summary	Planned (sharding)
NF R-008	Rule change propagation	Active rules converge on all replicas in ≤ 15 s after approval	<code>rulesService</code> cache TTL 15 s plus <code>rules.activated</code> event	Built

2. Scalability

ID	Requirement	Target	Verification	Support
NF R-009	Horizontal scaling of the API tier	Stateless replicas behind a load balancer; scale 2 → 12 pods on CPU above 60%	K8s HPA test	Partial (stateless; shared token-revocation and rate-limit store planned, E-15)
NF R-010	Data volume	6 M profiles, 12 M source records, 50 M messages per year, without query-plan regressions (all filters use indexed columns)	<code>EXPLAIN</code> checks in <code>test/pg/*.test.js</code>	Built (filters restricted to declared indexed columns: <code>schema.js</code> , <code>query.js</code>)
NF R-011	Background work scales out	Outbox relay safe to run on N replicas (<code>SKIP LOCKED</code>), at-least-once delivery, idempotent handlers, maximum 5 attempts	Integration test	Built (<code>outboxEventBus.js</code>)
NF R-012	Event streaming readiness	The outbox can forward to Kafka or Pub/Sub without changing publishers	Design review	Planned

3. Availability and resilience

ID	Requirement	Target (SLO)	Verification	Support
NF R-013	Customer-facing purchase path (<code>/api/customer/*</code> , <code>/api/partner/v1/*</code> , certificate verify)	99.9% monthly (≤ 43.8 min downtime)	Uptime probe on <code>/health/ready</code> and synthetic purchase	Partial
NF R-014	Staff console and APIs	99.5% monthly, business hours 07:00–21:00 ICT	Uptime probe	Partial
NF R-015	Graceful degradation	Failure of one integration (wallet, core, ZNS, SMS, push, voice) affects only that feature. Circuit opens after 5 failures and half-opens after 30 s.	Chaos test; <code>/api/ops/status</code> circuit state	Built
NF R-016	No double charge	0 duplicate debits under retries (idempotency key on order and wallet)	<code>test/integration</code> purchase-replay test	Built

ID	Requirement	Target (SLO)	Verification	Support
NF R-017	Compensation	100% of issuance failures after payment refunded or flagged; reconciliation finds 0 unexplained mismatches daily	Reconciliation job report	Built

4. Security (OWASP ASVS 4.0 Level 2)

ID	Requirement	Target	Verification	Support
NF R-018	ASVS L2 compliance across V1–V14	0 open High or Critical findings at go-live; annual third-party penetration test	<code>test/security/*.test.js</code> , external pentest	Partial
NF R-019	Authentication (ASVS V2)	Passwords 12–128 characters, hashed with script; lockout after 5 failures for 15 minutes; TOTP MFA mandatory for privileged roles; login rate limit 10/min per IP	Security tests	Built
NF R-020	Session management (ASVS V3)	Access token TTL ≤ 30 min; logout revocation effective across all replicas	Security tests	Partial (revocation per replica)
NF R-021	Access control (ASVS V4)	Deny by default; RBAC + ABAC on every route; partner scope = own quotes and policies; customer scope = own vehicle; 0 IDOR findings	<code>test/security/authz.test.js</code>	Built (gaps E-18)
NF R-022	Input validation (ASVS V5)	Allow-list schemas on every body and query (types, lengths, enums, patterns); body ≤ 1 MB; parameterised SQL only; only declared columns filterable	Fuzz tests	Built (<code>validation.js</code> , <code>routes.js</code> , <code>schemas</code> , <code>query.js</code>)
NF R-023	Cryptography (ASVS V6)	PII encrypted at rest with AES-256-GCM, with key rotation via key IDs (<code>DATA_KEYS</code> , <code>DATA_KEY_ACTIVE</code>); HMAC blind index for phone search; API keys stored as SHA-256; TLS 1.2+ in transit; HSTS in production	Config review	Built
NF R-024	HTTP security (ASVS V14)	Strict CSP (<code>default-src 'self'</code> , no inline script), <code>X-Frame-Options: DENY</code> , <code>nosniff</code> , <code>Referrer-Policy: no-referrer</code> , CORS allow-list, global rate limit 300 req/min	<code>test/security/headers.test.js</code>	Built (<code>security.js</code>)
NF R-025	Secrets	No secrets in code; <code>*_FILE</code> convention for K8s, Docker or Vault secrets; production refuses to boot with missing secrets or with demo mode on	Boot test	Built (<code>config.js</code>)
NF R-026	Dependency hygiene	<code>npm audit --omit=dev --audit-level=high</code> passes in CI; minimal runtime dependencies (currently only <code>pg</code>)	CI	Built (script); CI pipeline Planned

ID	Requirement	Target	Verification	Support
NF R-027	Voice-channel fraud resistance	The bot never requests an OTP, card or payment; plate verified before any personal data is disclosed; plate and phone masked in summaries	Script review; voicebot unit tests	Built

5. Privacy and data protection

Legal basis to confirm with TASCO legal: the Personal Data Protection Law **91/2025/QH15** (effective 2026), **Decree 13/2023/ND-CP** on personal data protection, **Decree 91/2020/ND-CP** on spam messages and calls, the Law on Insurance Business **08/2022/QH15**, and any data-localisation obligations under the Cybersecurity Law and its implementing decree. The controls below are conservative engineering defaults, **not legal advice**.

ID	Requirement	Target	Verification	Support
NF R-028	Consent by purpose and channel	Marketing and call consent stored per profile; enforced before every marketing message and call; changes audited and honoured within ≤ 1 minute	Integration tests on <code>canContact</code>	Built
NF R-029	Data-subject rights	Access (self-service download and staff export) and erasure by anonymisation, completed within ≤ 72 h of a verified request. Legal-retention exceptions documented.	DSAR tests	Partial (E-19)
NF R-030	Data residency	Personal data of Vietnamese data subjects stored and processed in a hosting location approved by TASCO legal (a Vietnam region if required). A cross-border transfer impact assessment is filed if any processor is offshore (for example a voice-AI vendor).	Architecture review	Planned (confirm with TASCO legal)
NF R-031	Data minimisation and masking	Staff without <code>profile:read_pii</code> never see full name or phone; handoffs carry masked phone; the public certificate check shows a masked plate and no PII	Security tests	Built
NF R-032	Processing records and DPIA	A Data Protection Impact Assessment and processing register maintained for each purpose (renewal, conquest, bot calls, partner sharing)	Compliance sign-off	Planned
NF R-033	Synthetic data outside production	Non-production environments use synthetic data only (<code>syntheticVetcSource.js</code>) or irreversibly masked extracts	Environment audit	Built (synthetic generator)

6. Accessibility and usability

ID	Requirement	Target	Verification	Support
NF R-034	Accessibility	WCAG 2.2 Level AA for the staff console and customer app: contrast $\geq 4.5:1$, full keyboard operation, visible focus, target size $\geq 24 \times 24$ px, labelled form fields, <code>prefers-reduced-motion</code> respected	axe-core automated scan (0 serious) plus manual screen-reader check (TalkBack and VoiceOver)	Planned
NF R-035	Customer task efficiency	Renew from a reminder in ≤ 3 taps after opening the link; renewal completed in ≤ 60 s median	Usability test ($n \geq 8$ per segment); adoption target in <code>insightsService</code>	Planned
NF R-036	Staff task efficiency	Agent sees the next lead and talking points in ≤ 2 clicks from home; handoff first contact within 2 business hours	Usability test; handoff timestamps	Planned
NF R-037	Explainability	Every score, NBA and benefit shown to staff carries a human-readable reason	UI review	Built (API: <code>reasons[]</code> , <code>nextBestAction.reason</code> , <code>benefits[].why</code>)
NF R-038	Help	Contextual help drawer on every console screen, in Vietnamese and English	UI review	Planned

7. Localisation

ID	Requirement	Target	Verification	Support
NFR -039	Bilingual UI	Vietnamese (default for customers) and English, switchable at runtime. 100% of UI strings externalised.	Pseudo-localisation test	Planned
NFR -040	Vietnamese conventions	Dates dd/mm/yyyy; currency vi-VN formatting (for example 480.700 đ); full diacritics; accent-insensitive search and matching	Unit tests (<code>viDate</code> , <code>stripDiacritics</code>)	Built (backend)
NFR -041	Customer copy in Vietnamese reviewed by TASCO	100% of templates and bot lines approved through maker-checker before activation	Rules audit trail	Built (workflow)

8. Maintainability and quality

ID	Requirement	Target	Verification	Support
NF R-042	Automated test coverage	Lines $\geq 80\%$, functions $\geq 80\%$, branches $\geq 70\%$ (excluding CLI, server bootstrap and the PG adapter, which has its own suite)	<code>npm run test:coverage</code> (thresholds configured in <code>package.json</code>)	Partial (thresholds configured; tests to be written, E-20)

ID	Requirement	Target	Verification	Support
NF R-043	Static analysis	ESLint 9 with 0 errors on every commit	<code>npm run lint</code> in CI	Partial (script present; config file to be added)
NF R-044	Architecture	Hexagonal: pure domain (<code>src/domain</code>), application services, adapters behind ports; no business thresholds in domain code	Code review; dependency rule check	Built (exceptions E-05)
NF R-045	API-first	100% of routes described in OpenAPI 3, generated from the route table (<code>npm run job openapi</code>)	CI diff on <code>docs/api/openapi.json</code>	Built
NF R-046	Schema governance	DB migrations match the collection registry; applied migrations are never edited	<code>test/unit/schema.test.js</code> (planned)	Built (registry and DDL generator)

9. Observability

ID	Requirement	Target	Verification	Support
NF R-047	Metrics	Prometheus <code>/metrics</code> : request rate, errors and duration by route; <code>quotes_total</code> , <code>orders_completed_total</code> , <code>messages_total</code> , <code>voice_calls_total</code> , <code>integration_calls_total</code> , short-circuits	Dashboard review	Built
NF R-048	Logs	Structured JSON logs with request ID (<code>X-Request-Id</code> propagated); no PII in logs	Log review; security test	Built
NF R-049	Alerting	Alerts on SLO burn rate, circuit open > 5 min, outbox backlog > 10k or age > 10 min, failed jobs, audit-chain verification failure	Alert runbook test	Planned
NF R-050	Business observability	Growth, economics, adoption and governance dashboards refreshed ≤ 5 min	FR-100 – FR-102	Built (on demand)

10. Disaster recovery and backup

ID	Requirement	Target	Verification	Support
NFR -051	Recovery point objective	RPO ≤ 5 minutes (PostgreSQL PITR with continuous WAL archiving)	Quarterly restore drill	Planned (infrastructure)
NFR -052	Recovery time objective	RTO ≤ 1 hour for the purchase path; ≤ 4 hours for the full platform	Annual DR exercise	Planned
NFR -053	Backups	Daily full backups kept 35 days and monthly backups kept 13 months, encrypted, in a separate account or region approved under NFR-030	Backup report	Planned
NFR -054	Audit integrity after restore	Audit hash chain verifies (<code>GET /api/audit/verify</code>) after every restore	DR runbook	Built (verify)

11. Portability and deployment

ID	Requirement	Target	Verification	Support
NF R-055	Runtime	Node.js ≥ 22.12 LTS, PostgreSQL 15+; an in-memory store for demo and tests with identical behaviour	CI matrix	Built
NF R-056	Packaging	OCI container image (non-root, read-only filesystem, health probes /health/live and /health/ready)	Image scan (0 Critical)	Planned (Dockerfile to be added)
NF R-057	Targets	Deployable to Kubernetes (Helm or Kustomize; CronJobs for <code>journeys</code> , <code>recompute</code> , <code>reconcile</code> , <code>retention</code> , <code>relay</code>) and to Railway or a similar PaaS for demo and UAT. Cloud-agnostic, with no proprietary managed services required.	Deployment rehearsal	Partial (12-factor config, job CLI built; manifests planned)
NF R-058	Configuration	12-factor: all settings from the environment; secrets via <code>*_FILE</code>	Config review	Built

12. Auditability

ID	Requirement	Target	Verification	Support
NFR -059	Completeness	100% of state-changing operations and all PII views audited (FR-097)	Audit coverage test	Built
NFR -060	Immutability	Audit log is append-only (a DB trigger rejects UPDATE and DELETE) and hash-chained; verification runs daily	<code>db/migrations/001_init.sql</code> trigger; scheduled verify	Built
NFR -061	Traceability of decisions	Every lead evaluation can be reproduced from the rule version (ID and checksum) and facts in force at the time	Rules snapshot in <code>/api/ops/status</code>	Partial (store rule version on the lead: planned)

13. Configurability

ID	Requirement	Target	Verification	Support
NF R-062	No hardcoded business rules	100% of thresholds, weights, tariffs, rates, journeys, copy, consent policy, commission and retention in rule kinds, changeable by the business through maker-checker without a release	Code review checklist; grep for numeric literals in <code>src/domain</code> and <code>src/application</code>	Partial (E-05 lists the remaining literals)
NF R-063	Safe change	Every rule change validated, simulated (scoring, NBA, journeys, benefits), approved by a second person, versioned and reversible	FR-083 – FR-087	Built
NF R-064	Lead time for business change	≤ 1 business day from request to activation for a rule change	Adoption dashboard target	Built (workflow)

14. Data retention

ID	Requirement	Target	Verification	Support
NFR-065	Retention schedule	Source records 365 days (delete); profiles 1,825 days after last activity with no active policy (anonymise); voice recordings and transcripts 180 days (delete); messages 365 days (archive); orders and certificates 3,650 days (archive, financial records); audit log 3,650 days (archive, never deleted early)	Retention job report	Partial (deletes built for source records and voice sessions; archival pipeline planned, E-09)
NFR-066	Legal hold	A legal hold flag suspends deletion for named entities	Retention test	Planned

15. Compliance-by-design (cross-cutting)

ID	Requirement	Target	Verification	Support
NFR-067	No discount language reaches customers	0 customer messages containing <code>copy_guard</code> phrases (validated at save and blocked at send)	<code>messageStatus.blocked</code> = 0 after go-live	Built
NFR-068	Contact hygiene	0 marketing contacts outside 08:00–20:00 ICT or above caps	Message log analysis	Built for journeys and triggers; campaign route gap E-01
NFR-069	Commission caps	0 commission lines above the statutory cap	Validator plus statement audit	Built